

Definition - What does **Malicious Software (Malware)** mean?

Malicious software, commonly known as malware, is any software that brings harm to a computer system. Malware can be in the form of worms, viruses, trojans, spyware, adware and rootkits, etc., which steal protected data, delete documents or add software not approved by a user.

Malware is software designed to cause harm to a computer and user. Some forms of malware “spy” on user Internet traffic. Examples include spyware and adware. Spyware monitors a user’s location and if enabled, it can capture sensitive information, e.g., credit card numbers, promoting identity theft. Adware also acquires user information, which is shared with advertisers and then integrated with unwanted, triggered pop-up ads.

Worms and viruses behave differently, as they can quickly proliferate (increase rapidly) and undermine (weaken/damage) an entire computer system. They also may perform unsavory (unpleasant) activities from a user’s computer without the user’s knowledge. In the wake of a virus or worm, a computer system can experience significant damage.

- A **worm** is a standalone piece of malicious software that reproduces itself and spreads from computer to computer.
- A **virus** is a piece of computer code that inserts itself within the code of another standalone program, then forces that program to take malicious action and spread itself.
- A **trojan** is a program that cannot reproduce itself but masquerades as something the user wants and tricks them into activating it so it can do its damage and spread.
- - **Spyware** is [defined by Webroot Cybersecurity](#) as "malware used for the purpose of secretly gathering data on an unsuspecting user." In essence, it *spies* on your behavior as you use your computer, and on the data you send and receive, usually with the purpose of sending that information to a third party. A **keylogger** is a specific kind of spyware that records all the keystrokes a user makes—great for stealing passwords.
 - A **rootkit** is, as [described by TechTarget](#), "a program or, more often, a collection of software tools that gives a threat actor remote access to and control over a computer or other system." It gets its name because it's a kit of tools that (generally illicitly) gain *root* access (administrator-level control, in Unix terms) over the target system, and use that power to hide their presence.
 - **Adware** is malware that forces your browser to redirect to web advertisements, which often themselves seek to download further, even more malicious software. As [The New York Times notes](#), adware often piggybacks onto tempting "free" programs like games or browser extensions.
 - **Ransomware** is a flavor of malware that encrypts your hard drive's files and demands a payment, usually in Bitcoin, in exchange for the decryption key. Several high-profile malware outbreaks of the last few years, such as [Petya](#), are [ransomware](#). Without the decryption key, it's mathematically impossible for victims to regain access to their files. So-called **scareware** is a sort of shadow version of ransomware; it claims to have taken control of your computer and demands a ransom, but actually is just using [tricks like browser redirect loops](#) to make it seem as if it's done more damage than it really has, and unlike ransomware can be relatively easily disabled.
- **Spyware**- Spyware is any technology that aids in gathering information about a person or organization without their knowledge. On the Internet (where it is

sometimes called a Spybot or tracking software), Spyware is programming that is put in someone's computer to secretly gather information about the user and relay it to advertisers or other interested parties. Spyware can get in a computer as a software virus or as the result of installing a new program.

- Virus- a virus is a program or programming code that replicates by being copied or initiating its copying to another program, computer boot sector or document. Viruses can be transmitted as attachments to an e-mail note or in a downloaded file, or be present on a diskette or CD
- Worm- a worm is a self-replicating virus that does not alter files but duplicates itself. It is common for worms to be noticed only when their uncontrolled replication consumes system resources, slowing or halting other tasks.
- Logic bomb- a logic bomb is programming code, inserted surreptitiously or intentionally, that is designed to execute (or "explode") under circumstances such as the lapse of a certain amount of time or the failure of a program user to respond to a program command. It is in effect a delayed-action computer virus or Trojan horse. A logic bomb, when "exploded," may be designed to display or print a spurious message, delete or corrupt data, or have other undesirable effects.
- Trapdoor- is a method of gaining access to some part of a system other than by the normal procedure (e.g. gaining access without having to supply a password). Hackers who successfully penetrate a system may insert trapdoors to allow them entry at a later date, even if the vulnerability that they originally exploited is closed. There have also been instances of system developers leaving debug trapdoors in software, which are then discovered and exploited by hackers.

A trap door is a secret entry point into a program that allows someone that is aware of the trap door to gain access without going through the usual security access procedures. Trap doors have been used legitimately for many years by programmers to debug and test programs. Trap doors become threats when they are used by unscrupulous programmers to gain unauthorized access. It is difficult to implement operating system controls for trap doors. Security measures must focus on the program development and software update activities.

What is eCommerce Security?

eCommerce security refers to the principles which guide safe electronic transactions, allowing the buying and selling of goods and services through the Internet, but with protocols in place to provide safety for those involved. Successful business online depends on the customers' trust that a company has eCommerce security basics in place.

Privacy

One of the most obvious eCommerce security basics is privacy, which in this situation means not sharing information with unauthorized parties. When you shop online, your personal details or account information should not be accessible to anyone except the seller you have chosen to share it with. Any disclosure of that information by the merchant would be a breach of confidentiality. The business is

responsible to provide at least the minimum in encryption, virus protection, and a firewall so that bank details and credit card information remain private.

Integrity

A second concept which is crucial within secure [eCommerce](#) is the idea of integrity—that none of the information shared online by the customer will be altered in any way. This principle states that a secure transaction includes unchanged data—that the business is only using exactly what was entered into the Internet site by the buyer. Any tampering with information is breaking the confidence of the buyer in the security of the transaction and the integrity of the company in general.

Authentication

For eCommerce to take place, both seller and buyer have to be who they say they are. A business cannot sell unless it's real, the products are real, and the sale will go through as described online. The buyer must also provide proof of identification so that the merchant can feel secure about the sale. In eCommerce, fraudulent identification and authentication are possible, and many businesses hire an expert to make sure these kinds of eCommerce security basics are in place. Common solutions include technological solutions—customer logins and passwords or additional credit card PINs.

Non-repudiation

Repudiation is denial, and good business depends on both buyers and sellers following through on the part of the transaction which originated with them—not denying those actions. Since eCommerce happens in cyberspace, usually without any live video, it can feel less safe and sure. The legal principle of non-repudiation adds another level of security by confirming that the information which was sent between parties was indeed received and that a purchase or email or signature cannot be denied by the person who completed the transaction.

Customers who don't feel transactions are secure won't buy. Hesitation on the part of the buyer will destroy eCommerce potential. Any breach will cost a business in lost revenues and consumer trust. These eCommerce security basics can guide any business owner regarding safe online transaction protocol.

Security is an essential part of any transaction that takes place over the internet. Customers will lose his/her faith in e-business if its security is compromised. Following are the essential requirements for safe e-payments/transactions –

- **Confidentiality** – Information should not be accessible to an unauthorized person. It should not be intercepted during the transmission.
- **Integrity** – Information should not be altered during its transmission over the network.
- **Availability** – Information should be available wherever and whenever required within a time limit specified.
- **Authenticity** – There should be a mechanism to authenticate a user before giving him/her an access to the required information.

- **Non-Repudiability** – It is the protection against the denial of order or denial of payment. Once a sender sends a message, the sender should not be able to deny sending the message. Similarly, the recipient of message should not be able to deny the receipt.
- **Encryption** – Information should be encrypted and decrypted only by an authorized user.
- **Auditability** – Data should be recorded in such a way that it can be audited for integrity requirements.

Measures to ensure Security

Major security measures are following –

- **Encryption** – It is a very effective and practical way to safeguard the data being transmitted over the network. Sender of the information encrypts the data using a secret code and only the specified receiver can decrypt the data using the same or a different secret code.
- **Digital Signature** – Digital signature ensures the authenticity of the information. A digital signature is an e-signature authenticated through encryption and password.
- **Security Certificates** – Security certificate is a unique digital id used to verify the identity of an individual website or user.

Security Protocols in Internet

We will discuss here some of the popular protocols used over the internet to ensure secured online transactions.

Secure Socket Layer (SSL)

It is the most commonly used protocol and is widely used across the industry. It meets following security requirements –

- Authentication
- Encryption
- Integrity
- Non-reputability

"https://\" is to be used for HTTP urls with SSL, where as "http://\" is to be used for HTTP urls without SSL.

Secure Hypertext Transfer Protocol (SHTTP)

SHTTP extends the HTTP internet protocol with public key encryption, authentication, and digital signature over the internet. Secure HTTP supports multiple security mechanism, providing security to the end-users. SHTTP works by negotiating encryption scheme types used between the client and the server.

Secure Electronic Transaction

It is a secure protocol developed by MasterCard and Visa in collaboration. Theoretically, it is the best security protocol. It has the following components –

- **Card Holder's Digital Wallet Software** – Digital Wallet allows the card holder to make secure purchases online via point and click interface.
- **Merchant Software** – This software helps merchants to communicate with potential customers and financial institutions in a secure manner.
- **Payment Gateway Server Software** – Payment gateway provides automatic and standard payment process. It supports the process for merchant's certificate request.

- **Certificate Authority Software** – This software is used by financial institutions to issue digital certificates to card holders and merchants, and to enable them to register their account agreements for secure electronic commerce.

What is Ecommerce Security?

The frequency and sophistication of cyber attacks has skyrocketed in recent years. Ecommerce security refers to the measures taken to protect your business and your customers against cyber threats.

Let's look at some terminology and common acronyms you should know:

Payment Card Industry Data Security Standard (PCI DSS).

PCI DSS (often referred to as just "PCI") is [an industry standard](#) that ensures credit card information collected online is being transmitted and stored in a secure manner.

International Organization for Standardization (ISO).

ISO is an international standard-setting body that creates requirements that guide businesses in making sure their products and processes are fit for purpose. One of their standards, ISO/IEC 27001:2013, covers data security. [Achieving this certification](#) means a business has high quality management systems, data security, risk-aversion strategies, and standardized business practices.

Personal Data.

Personal data or personal information refers to any data that can be linked back to a specific individual — most simply, this includes names, email addresses, and phone numbers. But it can get a little bit more complex as well. Any data set — even scrubbed of specific names or numbers — that can identify a particular person is considered personal data. Protecting personal data is particularly important when it comes to data privacy regulations like GDPR (more on that later).

Transport Layer Security (TLS), Secure Sockets Layer (SSL), and HTTPS authentication.

Utilizing SSL helps to authenticate and encrypt links between networked computers. Once you have an SSL certificate for your ecommerce site, you can move from HTTP to HTTPS, which serves as a trust signal to customers that your site is secure.

Multi-factor authentication (MFA), 2-factor authentication (2FA), or 2-step verification (2SV).

MFA, 2FA, and 2SV are sometimes used interchangeably — and they are similar — but there are differences among them. In addition to entering a username and password, all three of these methods require at least one further method of identity verification of a user logging in to a site — like your ecommerce store.

Here's a high-level explanation of the differences:

- 2SV may require the user to enter a one-time code, delivered via an email, text message, or phone call.
- 2FA goes a step further and may require the user to acknowledge their login attempt through another device, like opening a specific app on a mobile device while logging in from a laptop.
- MFA is similar to 2FA but can refer to the implementation of more than two factors of authentication.

Phishing

It is one of the common security threats of ecommerce where hackers masquerade as legitimate businesses and send emails to your clients to trick them into revealing their sensitive information by simply presenting them with a fake copy of your legitimate website or anything that allows the customer to believe the request is coming from the business.

Common phishing techniques include emailing your customers or your team with fake “you must take this action” messages. This technique only works your customers follow through with the action and provide them access to their login information or other personal data which the hacker can exploit as per his benefit.